

DOC-020: HARDENING CHECKLIST

UFOSI - Universal Financing Optimized Syariah Intelligent-assistant

A. METADATA & GOVERNANCE CONTROL

Parameter Tata Kelola	Deskripsi & Identifikasi Dokumen
Kode Dokumentasi	DOC-020
Fase Tata Kelola	Security Hardening & Compliance Verification Phase
Nama Aplikasi Resmi	UFOSI - Universal Financing Optimized Syariah Intelligent-assistant
Versi Master	v1.0.0 - Updated: 05 June 2026
Status Dokumen	[v] Draft [] Under Review [] Approved

B. ACCOUNTABILITY & MATRIKS STAKEHOLDER

Peran Tata Kelola	Aktor / Pemangku Kepentingan	Uraian Tanggung Jawab Operasional
Document Owner	Security Engineer / Risk Stream	Bertanggung jawab penuh mendefinisikan standar pengerasan keamanan atau hardening, melakukan audit berkala, memberikan rekomendasi perbaikan, dan memverifikasi kepatuhan terhadap standar keamanan serta regulasi perbankan.
Target Implementer	System Engineer / IT Operations Team	Bertanggung jawab mengeksekusi konfigurasi teknis di server aplikasi, Kubernetes/K3s, container runtime, service exposure, backup, monitoring, dan evidence berdasarkan instruksi checklist ini.
Target Auditor / SOC	Security Operations Center	Memantau kepatuhan log, memvalidasi postur keamanan melalui berkas audit, meninjau potensi anomali keamanan, dan merespons jika terjadi pelanggaran kebijakan.
Application Owner	Business User / Pembiayaan SME	Memastikan bahwa data yang digunakan dalam pengujian dan demo tidak mengekspos informasi nasabah riil serta sesuai kebutuhan bisnis pembiayaan SME.
Developer Team	Lead Developer / Dev Stream	Memastikan aplikasi tidak mencetak secret pada log, endpoint sensitif menggunakan autentikasi, konfigurasi environment variable sesuai standar, dan image container menggunakan versi yang jelas.

C. TUJUAN STRATEGIS HARDENING

Dokumen ini berfungsi sebagai panduan teknis formal dan lembar verifikasi atau checklist untuk memastikan seluruh infrastruktur server yang menopang aplikasi UFOSI telah dikonfigurasi dengan standar keamanan yang memadai dari sisi Security Stream.

UFOSI memproses dokumen rahasia perbankan berupa PDF/scan rekening koran nasabah menggunakan OCR dan AI. Oleh karena itu, pencegahan akses tidak sah, pembatasan port, perlindungan database, pengelolaan secret, validasi logging, dan pengamanan evidence menjadi bagian penting untuk menjaga kerahasiaan data finansial dan mendukung prinsip keamanan internal perbankan.

Untuk fase Demo/UAT, checklist ini difokuskan pada kontrol hardening yang relevan dengan environment lab/staging, yaitu pembatasan exposure service, isolasi namespace Kubernetes, validasi akses backend dengan token, database tidak diexpose langsung ke user, monitoring tersedia, backup dilakukan sebelum operasi berisiko, serta evidence tidak menampilkan informasi sensitif. Untuk fase production, beberapa aspek tetap ditandai sebagai pending review, seperti SIEM integration, production firewall review, rotasi secret, dan audit otomatis berbasis CIS benchmark.

D. DAFTAR PERIKSA Pengerasan Keamanan (Hardening Checklist)

System Engineer wajib melengkapi, memverifikasi, dan menandai setiap parameter di bawah ini sebelum aplikasi dinyatakan siap untuk tahap produksi atau Go-Live.

Komponen Hardening	Spesifikasi Teknis & Instruksi Eksekusi	Metode Verifikasi	Status (Pass/Fail)
CIS Benchmark Compliance	Terapkan konfigurasi dasar sistem operasi Linux Server minimal mengikuti prinsip CIS Level 1. Untuk fase Demo/UAT, fokus utama adalah memastikan service tidak relevan tidak digunakan, workload aplikasi berjalan di Kubernetes namespace terpisah, serta tidak ada service sensitif yang diexpose langsung ke user.	Verifikasi manual menggunakan system service review dan package review. Command referensi: systemctl --type=service --state=running, dpkg -l, serta review service aktif pada VM 1.	[v] Pass Demo/UAT [] Fail [v] Pending Production Review

	Audit otomatis seperti Lynis/OpenSCAP direkomendasikan sebelum production.		
SSH Hardening	SSH hanya digunakan untuk admin terotorisasi. Root login wajib dinonaktifkan. Penggunaan SSH key direkomendasikan. Untuk Demo/UAT, SSH port 22 masih digunakan karena kebutuhan remote operasional dan evidence collection oleh tim IT Ops. Untuk production, direkomendasikan custom SSH port, password authentication disabled, SSH key Ed25519, dan source IP allowlist.	Cek konfigurasi dengan sudo grep -E "PermitRootLogin PasswordAuthentication PubkeyAuthentication ClientAliveInterval" /etc/ssh/sshd_config. Uji login hanya dari workstation admin terotorisasi.	[v] Pass Demo/UAT [] Fail [v] Pending Production Hardening
Logging Enabled & Local Evidence Collection	Logging sistem dan aplikasi wajib aktif. Untuk Demo/UAT, log aplikasi dikumpulkan melalui kubectrl logs dan log OS diperiksa melalui journalctl. Evidence log disimpan di folder ~/ufosi-ops/logs dan ~/ufosi-ops/evidence. Integrasi SIEM belum diterapkan pada fase Demo/UAT.	Verifikasi log aplikasi menggunakan kubectrl logs deployment/ufosi-backend -n ufosi --tail=200, kubectrl logs deployment/ufosi-frontend -n ufosi --tail=200, dan journalctl untuk OS log.	[v] Pass Demo/UAT [] Fail [v] Pending SIEM Integration
Logging Centralization / SIEM	Untuk production, log aktivitas server, Kubernetes, backend API, OCR process, dan security event perlu dikirim ke centralized log server atau SIEM menggunakan kanal aman. Untuk Demo/UAT, centralized SIEM belum diterapkan dan dicatat sebagai open item.	Cek keberadaan target log forwarding, agent SIEM, atau konfigurasi remote logging.	[] Pass [] Fail [v] Pending Production
NTP Configured / Time Synchronization	Waktu sistem harus sinkron agar timestamp log valid saat audit dan troubleshooting. Sinkronisasi waktu dibutuhkan untuk memastikan urutan event pada backend, Kubernetes, database, Prometheus, dan Grafana dapat dianalisis secara akurat.	Jalankan timedatectl status. Expected: NTP service active dan system clock synchronized.	[v] Pass Demo/UAT [] Fail
Kubernetes Namespace Isolation	Aplikasi UFOSI harus berjalan dalam namespace terpisah dari monitoring. Namespace aplikasi adalah ufosi, sedangkan monitoring menggunakan namespace monitoring. Pemisahan ini membantu pengelolaan workload, akses, observability, dan troubleshooting.	Jalankan kubectrl get ns, kubectrl get pods -n ufosi, dan kubectrl get pods -n monitoring.	[v] Pass [] Fail
Service Exposure Control	Frontend diexpose melalui NodePort 30080. Backend API diexpose melalui NodePort 30081 untuk kebutuhan Demo/UAT dan integrasi frontend browser. AI/OCR dan PostgreSQL tidak diexpose langsung ke user dan tetap menggunakan ClusterIP internal Kubernetes.	Jalankan kubectrl get svc -n ufosi. Pastikan frontend memiliki NodePort 30080, backend API memiliki NodePort 30081, sedangkan AI/OCR dan DB tidak memiliki NodePort publik.	[v] Pass [] Fail
Backend API Access Control	Backend endpoint sensitif harus menggunakan authentication Bearer token. Validasi GET DB	Login user test, ambil access token, lalu hit endpoint authenticated GET. Evidence menunjukkan HTTP/1.1 200 OK untuk endpoint GET DB yang membutuhkan token.	[v] Pass [] Fail

	dilakukan melalui login user test, token extraction, lalu akses endpoint menggunakan Authorization Bearer token. Endpoint yang divalidasi mencakup users profile, nasabah, banks, jenis pembiayaan, dan analytics summary.		
Database Exposure Control	PostgreSQL database tidak boleh diexpose langsung ke client/user. Akses database hanya dilakukan melalui backend service dan internal Kubernetes network. Service database tetap berada di ClusterIP port 5432.	Jalankan kubectl get svc -n ufosi dan pastikan database tidak menggunakan NodePort. Verifikasi koneksi DB menggunakan kubectl exec deployment/ufosi-db -n ufosi -- psql -U ufo_admin -d "ufo-db" -c '\conninfo'.	[v] Pass [] Fail
Secret Management	Secret seperti DATABASE_URL, JWT secret, SMTP password, dan Gemini API key wajib disimpan menggunakan Kubernetes Secret atau mekanisme secret management yang aman. Secret tidak boleh dimasukkan ke screenshot publik, Word evidence, atau PPT. Karena beberapa secret pernah dibagikan selama proses testing, secret wajib dirotasi setelah Demo/UAT.	Jalankan kubectl get secret -n ufosi untuk memastikan secret object tersedia. Jangan melakukan kubectl get secret -o yaml untuk dokumentasi publik.	[v] Pass Demo/UAT [] Fail [v] Rotate After Demo
Container Image Version Control	Image aplikasi harus menggunakan tag versi eksplisit, bukan latest. Final baseline yang digunakan untuk Demo/UAT adalah frontend v1.1.1, backend v1.1.1, AI/OCR v1.1.0, dan database postgres:16.	Jalankan kubectl describe deployment ufosi-frontend -n ufosi grep -i image, kubectl describe deployment ufosi-backend -n ufosi grep -i image, kubectl describe deployment ufosi-ai -n ufosi grep -i image, dan kubectl describe deployment ufosi-db -n ufosi grep -i image.	[v] Pass [] Fail
Image Runtime Validation	Image yang digunakan harus berhasil dipull/import ke runtime dan pod berhasil Running. Deployment harus berhasil rollout tanpa CrashLoopBackOff.	Jalankan docker images, sudo k3s ctr images ls, kubectl rollout status deployment, dan kubectl get pods -n ufosi -o wide.	[v] Pass [] Fail
Healthcheck Validation	Service utama harus memiliki healthcheck dan divalidasi setelah update. Frontend NodePort 30080, Backend NodePort 30081 /api/v1/health, AI/OCR internal /api/v1/health, dan database connection telah divalidasi.	Frontend: curl -I http://192.168.23.72:30080. Backend: curl -i http://192.168.23.72:30081/api/v1/health. AI/OCR: curl internal dari curl-test pod. DB: psql conninfo.	[v] Pass [] Fail
Monitoring Availability	Prometheus dan Grafana tersedia untuk observability Demo/UAT. Prometheus digunakan untuk readiness/metrics, sedangkan Grafana digunakan sebagai dashboard monitoring.	Prometheus: curl http://192.168.23.72:30090/-/ready. Grafana: curl -I http://192.168.23.72:30300. Cek juga kubectl get pods -n monitoring dan kubectl get svc -n monitoring.	[v] Pass Demo/UAT [] Fail
Self-Healing Validation	Kubernetes harus mampu memulihkan service ketika pod aplikasi dihapus. Backend self-healing telah diuji dengan delete pod backend, deployment berhasil rollout ulang, dan backend healthcheck kembali HTTP 200 OK.	Evidence: backend pod deleted, deployment "ufosi-backend" successfully rolled out, dan curl backend healthcheck menghasilkan HTTP/1.1 200 OK.	[v] Pass [] Fail
Backup Before Risky Operation	Sebelum operasi yang berisiko terhadap data, seperti cleanup duplicate	Evidence backup: ufo-db-backup-before-bank-cleanup.sql dengan ukuran file valid dan bukan 0 byte.	[v] Pass [] Fail

	bank, backup database wajib dilakukan menggunakan pg_dump.		
Data Cleanup & Integrity Validation	Duplicate data bank akibat seed berulang telah dibersihkan tanpa reset database penuh. Final tabel bank berisi tiga record unik: Bank Arunika, Bank Kencana, dan Bank Nusa. Duplicate check menghasilkan 0 rows.	Cek evidence bank-table-after-cleanup.txt, bank-duplicates-after-cleanup.txt, dan GET /api/v1/banks HTTP 200 OK.	[v] Pass [] Fail
Firewall / Port Restriction	Port yang digunakan untuk Demo/UAT harus terbatas pada kebutuhan operasional: SSH admin 22, frontend 30080, backend API 30081, Grafana 30300, dan Prometheus 30090. AI/OCR 8000 dan database 5432 tetap internal.	Cek service Kubernetes, port matrix DOC-006, dan firewall rule request DOC-007.	[v] Pass Demo/UAT [] Fail [v] Pending Production Firewall Review
Sensitive Evidence Handling	Evidence untuk dokumentasi tidak boleh menampilkan token, raw secret, DATABASE_URL lengkap, SMTP password, JWT secret, Gemini API key, atau Authorization Bearer token. Dokumentasi hanya boleh menggunakan summary PASS dan screenshot yang sudah dibersihkan dari secret.	Review seluruh screenshot sebelum dimasukkan ke Word/Docs/PPT. Gunakan evidence summary, bukan file login raw response jika mengandung token.	[v] Pass [] Fail

E. PROSEDUR PERSETUJUAN / SIGN-OFF

Dengan menandatangani dokumen checklist pengerasan keamanan ini, tim menyatakan bahwa server aplikasi UFOSI telah diperiksa dan dikunci sesuai standar keamanan yang berlaku untuk fase Demo/UAT.

Untuk fase production, beberapa kontrol masih membutuhkan review lanjutan, terutama SIEM integration, production firewall rule, rotasi secret, dan audit hardening otomatis.

Peran	Nama & Tanda Tangan	Tanggal
Diverifikasi oleh - Security Engineer		
Dieksekusi oleh - System Engineer		
Direview oleh - IT Operations Lead		
Diketahui oleh - Project Manager / Task Lead		

F. RINGKASAN STATUS HARDENING

Area Kontrol	Status Ringkas
OS & CIS Baseline	Pass Demo/UAT, pending production review
SSH Hardening	Pass Demo/UAT, pending production hardening
Logging Local	Pass Demo/UAT
SIEM Integration	Pending Production
NTP / Time Sync	Pass Demo/UAT
Namespace Isolation	Pass
Service Exposure	Pass
Backend API Auth	Pass
Database Exposure Control	Pass
Secret Management	Pass Demo/UAT, rotate after demo
Image Version Control	Pass
Runtime Validation	Pass
Healthcheck	Pass
Monitoring	Pass Demo/UAT
Self-Healing	Pass
Backup Before Risky Operation	Pass
Data Cleanup & Integrity	Pass
Firewall / Port Restriction	Pass Demo/UAT, pending production firewall review
Sensitive Evidence Handling	Pass

G. KESIMPULAN HARDENING

Berdasarkan hasil checklist, environment UFOSI untuk fase Demo/UAT dinyatakan memenuhi kontrol hardening minimum yang relevan. Aplikasi telah berjalan pada namespace Kubernetes terpisah, service sensitif seperti AI/OCR dan PostgreSQL tidak diexpose langsung ke user, backend API menggunakan access control berbasis Bearer token, image container menggunakan tag versi eksplisit, monitoring tersedia melalui Prometheus dan Grafana, serta self-healing Kubernetes telah divalidasi.

Beberapa kontrol masih perlu ditindaklanjuti sebelum production, yaitu audit CIS otomatis, integrasi centralized logging/SIEM, production-grade SSH hardening, review firewall permanen, dan rotasi secret setelah Demo/UAT. Seluruh evidence yang digunakan untuk dokumentasi wajib dibersihkan dari token, password, connection string, API key, dan data sensitif nasabah.

Dengan demikian, DOC-020 ini menjadi dasar verifikasi hardening teknis UFOSI untuk mendukung kesiapan Demo/UAT dan menjadi baseline perbaikan sebelum production readiness.